

CONFIDENTIAL – HACKATHON SUBMISSION

KAVACH

Zero-Trust Banking Security Ecosystem

Pitch Deck Blueprint

Architecture • Threat Intelligence • Security Flows

SBI YONO Shield • Tier-1 Fintech Hackathon • 2026

01 THE CORE VALUE PROPOSITION

KAVACH is a Zero-Trust, multi-layered banking security ecosystem that intercepts phishing attacks *before* the customer clicks — across SMS, WhatsApp, QR codes, and sideloaded APKs — while simultaneously verifying the cryptographic integrity of every installed application and the device OS itself, delivering enterprise-grade fraud prevention to the most vulnerable, low-literacy rural banking populations through audio-visual threat education and fully offline-resilient telemetry.

02 THE THREAT BRAIN – CLOUD BACKEND ENGINE

The KAVACH cloud backend is a production-grade **FastAPI microservice** (codename: **Omni-Scanner v2.0**) that operates as the centralized intelligence hub. It processes threats across **three parallel pipelines** and responds in real-time to both WhatsApp Cloud API webhooks and direct Flutter client requests.

2.1 Multi-Pipeline Architecture

Pipeline 1 – TEXT: Raw SMS/WhatsApp text → URL Extraction → 5-Gate Scan Pipeline
Pipeline 2 – IMAGE: WhatsApp image → QR Decode (pyzbar) → URL Extraction → 5-Gate Scan
Pipeline 3 – DOCUMENT: WhatsApp document → APK/DEX Extension + MIME Check → Sideload Block
Pipeline 4 – OCR: (Reserved) Screenshot → Tesseract OCR → URL Extraction → 5-Gate Scan

2.2 The 5-Gate URL Scan Pipeline

Every URL — whether from SMS text, QR code, or direct scan API — passes through a **sequential, fail-secure, 5-gate security pipeline**:

GATE	NAME	MECHANISM	OUTCOME
Gate 1	Redirect Trace	Expands URL shorteners (bit.ly, tinyurl, t.co) by following HTTP redirects to the final destination. HEAD-first with streamed GET fallback. 3-second timeout, 5-hop maximum to prevent infinite redirect loops.	Resolved URL forwarded
Gate 2	Dynamic Whitelist	Checks resolved domain against curated set of pre-verified official SBI domains (core portals + verified marketing domains). Whitelisted domains bypass all heuristic overhead — zero latency for legitimate traffic .	SAFE (immediate) or continue
Gate 3	Heuristic Rules Engine	(a) Brand Spoofing — flags domains containing "sbi", "yono", "statebank" that aren't whitelisted. (b) Homoglyph Detection — character-substitution patterns (o→0, i→1, e→3). (c) High-Risk TLD — disposable phishing TLDs (.xyz, .top, .tk, .ml, .click).	Heuristic reason or continue

Gate 4	Fuzzy Typo-Squatting	SequenceMatcher computes character-sequence similarity against Core Protected Assets. Domains exceeding 80% similarity but NOT whitelisted are flagged as zero-day typo-squats. Dynamic — catches novel variants without pattern updates.	FUZZY_TYPOSQUAT or continue
Gate 5	Threat Intelligence APIs	Queries VirusTotal (v3) and Google Safe Browsing (v4) with strict 3-second timeouts . Catches entirely unknown zero-day domains. API-flagged threats bypass WHOIS downgrade .	THREAT_INTEL block or continue

Post-Gate Logic: No gate fires → SAFE. Gate 3/4 fires → WHOIS Fallback (§5.3 Grey Alert). Gate 5 fires → PHISHING (globally confirmed).

2.3 The "Document Drop" Defense Mechanism

Intercepts **APK sideloading via WhatsApp document attachments** — fraudsters send malicious Android packages disguised as "banking updates."

1. When the Meta webhook receives a **document-type message**, the engine extracts `filename` and `mime_type`.
2. **Dual-check matrix**: Extension matching (`.apk`, `.xapk`, `.jar`, `.dex`) AND MIME type matching (`application/vnd.android.package-archive`, etc.).
3. If **either check** triggers → **immediate block** + WhatsApp auto-reply warning the user.
4. **Background telemetry task** logs the sideload attempt (sender, filename, timestamp) to the SIEM data lake.

2.4 The Automated OSINT Takedown Pipeline

When a URL is confirmed PHISHING, KAVACH initiates an **automated takedown protocol** as a FastAPI BackgroundTask — the user-facing reply is never delayed.

PHASE	OPERATION	DETAILS
Phase 1	OSINT Evidence Gathering	DNS A-record resolution (5s timeout) + live WHOIS lookup → registrar, abuse emails, registrant identity, nameservers, registration/expiration dates. Compiled into structured evidence package.
Phase 2	Google Safe Browsing Report	Submits phishing URL to Google Safe Browsing v4 (<code>threatMatches:find</code>). Contributes detection to the global Safe Browsing ecosystem across Chrome, Android, and all consumers.
Phase 3	Registrar Abuse Email	ICANN RAA §3.18-compliant abuse report via SMTP/TLS to WHOIS abuse contacts. Follows CERT-In / APWG / FIRST SOC conventions. Includes technical evidence, requested actions, and IT Act 2000 legal notice.

Each phase is independently fault-tolerant — a failure in one phase never prevents execution of subsequent phases. The pipeline produces a consolidated audit report with timestamps, evidence, and dispatch status.

03 THE ACTIVE SENTINEL – ANDROID / FLUTTER ENGINE

The on-device security enforcement layer, implemented as a **hybrid Flutter + Kotlin Native architecture** connected via three dedicated `MethodChannel` bridges.

3.1 Installer Verification — Accessibility & Notification Snooping Defense

The Problem: Accessibility Services can **read every pixel**, **press buttons autonomously**, and **intercept OTPs**. Notification Listeners can harvest **every banking notification and OTP**. These are the highest-risk attack vectors.

KAVACH's Approach: Rather than blocking ALL accessibility services, KAVACH uses **origin-based trust verification**:

1. **Enumerate** all active Accessibility Services via `AccessibilityManager` and Notification Listeners via `Settings.Secure`.

2. For each active service, invoke `getInstallerForPackage()` — queries PackageManager for the install source (API 30+: `InstallSourceInfo`; legacy: `getInstallerPackageName`).
3. Compare against **Trusted Installer whitelist**: Google Play Store, Huawei AppGallery, Samsung Galaxy Store, Xiaomi GetApps, OPPO/OnePlus/realme Store.
4. **Store-installed** → Allowed (TalkBack, password managers, legitimate tools pass).
5. **Sideloaded (NULL/unknown installer)** → Full-screen Red Alert + TTS warning + one-tap Uninstall + Telemetry report.
6. Both scans run **on every app lifecycle resume** — instant detection upon return.

3.2 Cryptographic Certificate Hashing — Fake App Detection

The **Cryptographic Gatekeeper** is a 4-gate security pipeline executed via native Kotlin SecurityManager:

GATE	CHECK	IMPLEMENTATION
Gate 1	Root / Jailbreak	Multi-vector root detection (see §3.4)
Gate 2	Trojan Overlay Scan	Enumerates all packages with GET_PERMISSIONS + GET_SERVICES. Flags non-system apps with SYSTEM_ALERT_WINDOW + RECEIVE_SMS combo OR BIND_ACCESSIBILITY_SERVICE — exact permission signatures of known banking trojans.
Gate 3	Certificate Extraction	Extracts signing certificate via PackageManager (API 28+: GET_SIGNING_CERTIFICATES; legacy: GET_SIGNATURES). Raw bytes → SHA-256 via MessageDigest → colon-separated hex fingerprint.
Gate 4	Hash Comparison	Live SHA-256 compared (case-insensitive) against known-good official hash. Mismatch = different private key = brand impersonation / re-packaging proof .

Verdicts: SAFE · ROOTED_DEVICE · TROJAN_DETECTED_{AppName} · INVALID_SIGNATURE · APP_NOT_FOUND

3.3 FLAG_SECURE — Tapjacking & Screen Recording Defense

At application launch, KAVACH sets the **FLAG_SECURE** flag on the Android window — a kernel-level instruction that:

- **Blocks ALL SYSTEM_ALERT_WINDOW overlays** — neutralizes invisible tapjacking attacks
- **Prevents ALL screen recording** — no third-party app can capture the screen
- **Blocks screenshots** — sensitive data cannot be captured via screenshot API
- **Disables screen mirroring/casting** — prevents external display credential harvesting

This is a **zero-overhead, kernel-enforced defense** operating at the Android compositor level. It cannot be bypassed by any user-space application.

3.4 Root / Jailbreak Detection — Device Integrity

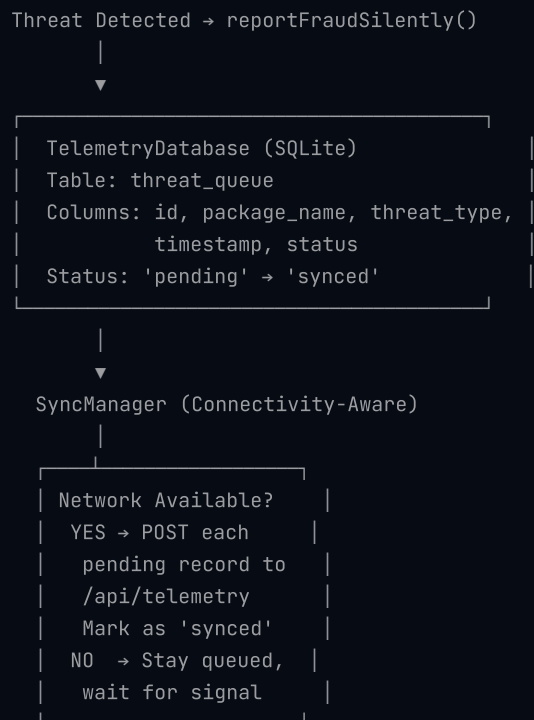
LAYER	CHECK	INDICATORS
Kotlin Native	Build Signature Analysis	Build.TAGS inspection for test-keys (custom ROM fingerprint)
	su Binary Filesystem Scan	14 known paths including /system/bin/.ext/.su, vendor-specific
	Root Package Audit	10 known packages: Magisk, SuperSU, Xposed, KingRoot, Cydia Substrate, RootCloak
Flutter Layer	Jailbreak Detection	su binary presence, RW /system partition
	Developer Mode	USB debugging status — external control vector
	Fail-Safe	Any exception → assumes compromised and locks down

Enforcement: Checked at launch AND every lifecycle resume. If compromised → **permanent black lockout screen** — all banking operations suspended until factory reset.

04 THE VAULT – OFFLINE RESILIENCE

SQLite "Store and Forward" Telemetry Architecture

KAVACH operates where connectivity is unreliable — rural India, patchy coverage, Airplane mode. The **Telemetry Vault** ensures **zero threat intelligence is ever lost**.



Key Design Decisions:

1. **Write-First, Sync-Later:** Every threat persisted to SQLite before any network call. UI thread never blocked.
2. **Connectivity-Aware Sync:** Subscribes to Android's `ConnectivityResult` stream. On any connectivity transition → auto-triggers batch sync.
3. **Idempotent Record-Level Sync:** Each record synced individually with 5-second timeout. Failed records remain pending for next attempt.
4. **Backend Ingestion:** `/api/telemetry` endpoint receives records, logs to SIEM, and auto-queues takedown for PHISHING telemetry.

05 CUSTOMER-CENTRIC UX FEATURES

5.1 Text-to-Speech (TTS) Audio Accessibility

Designed for India's **450+ million rural banking users** with limited literacy.

- **Engine:** `flutter_tts` — en-IN, speech rate **0.45x** (deliberately slow), max volume
- **Auto-Speak:** TTS begins automatically 600ms after any Red Alert opens — zero interaction required

- **Contextual Scripts:** Each verdict has a custom, conversational TTS message (e.g., *"Warning. [App] is trying to read your screen to steal your OTP..."*)
- **Massive Audio Button:** Full-width pulsing "PLAY AUDIO WARNING" with 48px speaker icon — impossible to miss
- **Universal Iconography:** Large shield/lock/thief icons replace text-heavy warnings

5.2 Tinder-Style "Scam Simulator" — Gamified Education

- **Swipe Left** = "SCAM" 🚫 **Swipe Right** = "SAFE" ✅ (plus massive button alternatives)
- **Scenario Cards:** WhatsApp lottery scam, official Play Store app, tampered QR code, fake OTP call
- **Audio Feedback:** TTS speaks explanation after each swipe — reinforces correct behavior, teaches risks
- **Shield Score:** Animated tracker ("2/4") with final TTS score announcement
- **Auto-Reset:** Unlimited re-play for reinforced learning

5.3 The "Grey Alert" Protocol — False-Positive Prevention

Problem: Banks launch new promotional domains that trigger Brand Spoofing heuristics → false positives erode trust.

1. When heuristic/fuzzy engine flags a domain, a **live WHOIS Fallback Verification** runs.
2. Registrant fields compared against known bank identifiers ("state bank of india", "sbi", "sbicaps", etc.).
3. **Match found** → Verdict downgraded to GREY_ALERT: "⚠️ *This is a new, unverified SBI promotional link. We recommend claiming offers inside your YONO app.*"
4. **No match / failure** → **Fail-secure** as PHISHING with full blocking.
5. Grey Alerts include full WHOIS evidence for transparency and audit.

KAVACH doesn't ask users to be security experts. It makes security invisible — intercepting threats before they reach the user, educating through play, and speaking warnings aloud so that everyone, from a tech-savvy professional to a first-generation smartphone user in rural India, is equally protected.